

INFORMACIÓN GENERAL					
Carrera:	Tecnología Superior Universitaria de Infraestructura de Redes y Cyber Seguridad.				
Asignatura:	Hacking Ético				
Estudiantes:	Gary Ávila Valdiviezo, Deisy Cabezas Viracocha, Bella Aracelly Guerrero Piza.				
Período Lectivo:	2025-2026	Jornada:	En Línea	Paralelo:	IRCY-L3N-B

INFORMACIÓN DE LA PRÁCTICA	
Práctica N°:	2
Tema de la Práctica:	Análisis de Vulnerabilidades con Nessus
Laboratorio / taller donde se desarrolló la práctica:	Laboratorio Virtual con máquinas virtuales.

INFORME	
OBJETIVOS:	
Objetivo General: Los alumnos aprenderán a configurar, ejecutar y analizar los resultados de un escaneo de vulnerabilidades utilizando Nessus contra un entorno controlado (Metasploitable 3), identificando vulnerabilidades críticas y generando un reporte básico.	
MATERIALES:	
MÓDULO: Metasploitable3 Wiki. Recuperado de GitHub. GitHub Creating a vulnerable node based on the vulnerability MS17-010. arXiv. arXiv Creating a vulnerable node based on the vulnerability MS17-010. arXiv. https://arxiv.org/abs/2401.14979	INSUMOS / MATERIALES: 1. Máquina virtual con Nessus 2. Máquina virtual Metasploitable 3 3. Ambas máquinas deben estar en la misma red y poder comunicarse (verificar con ping).

FUNDAMENTO TEÓRICO
Escenario Eres un analista de seguridad encargado de evaluar la seguridad de un servidor interno de desarrollo (Metasploitable 3) antes de su migración a producción. Debes identificar vulnerabilidades que puedan ser explotadas y priorizar su remediación. La protección de servidores en contextos empresariales constituye una práctica necesaria dentro de las fases de desarrollo seguro, en particular cuando las plataformas transitan desde entornos de prueba hacia la puesta en producción. Como señala Tenable (s.f.), los exámenes de vulnerabilidades hacen posible detectar deficiencias potenciales capaces de afectar la integridad, disponibilidad o confidencialidad de los servicios antes de que un atacante logre utilizarlas. Aplicaciones como Nessus llevan a cabo escaneos automatizados de puertos, servicios y configuraciones visibles, reconociendo versiones desactualizadas, ajustes deficientes y elementos vulnerables que exigen atención prioritaria. Esta clase de revisión resulta crucial en servidores como Metasploitable 3, concebidos justamente para exhibir vectores de ataque y una exposición realista.

Dentro de los componentes más sensibles evaluados figuran las aplicaciones web, dado que los servicios HTTP/HTTPS representan con frecuencia accesos habituales para amenazas externas. De acuerdo con Acunetix (s.f.), las fallas en servicios web suelen incluir vulnerabilidades como ejecución de código remota, inyección de comandos, divulgación de archivos predeterminados y versiones sin soporte, siendo estas últimas particularmente graves debido a la falta de actualizaciones de seguridad. En el estudio efectuado, Apache Tomcat mostró diversos riesgos vinculados a ediciones sin mantenimiento, las cuales poseen deficiencias registradas públicamente que pueden ser aprovechadas sin requerir autenticación, incrementando de forma considerable la superficie de ataque.

El cifrado cumple asimismo una función crucial en la salvaguarda de la información que se transmite a través de canales encriptados. La vulnerabilidad Logjam (CVE-2015-4000) deja al descubierto las limitaciones propias del intercambio de claves Diffie-Hellman que emplea parámetros reducidos o reutilizados. Tal como indican IBM (s.f.) y trabajos difundidos en ArXiv, los grupos DH de longitud insuficiente permiten que un intruso degrade la conexión TLS, quebrante la encriptación y pueda leer o alterar información durante su transmisión. Este tipo de fallos impacta de manera directa la protección en servicios que dependen de SSL/TLS para resguardar credenciales, sesiones y datos confidenciales entre clientes y servidores.

En último término, la existencia de servicios no actualizados o con configuraciones poco seguras, como Elasticsearch o Tomcat, evidencia la relevancia de sostener una gestión continua de actualización y fortalecimiento de configuraciones. Las vulnerabilidades que permiten ejecución remota sin autenticación representan una de las amenazas más graves, ya que posibilitan el dominio completo del sistema afectado. La documentación técnica coincide en que la unión de servicios obsoletos, cifrado frágil y exposición de interfaces administrativas eleva de manera drástica el riesgo operativo del entorno (Tenable, s.f.; Acunetix, s.f.). Por ello, una base teórica apropiada recalca que la detección temprana de vulnerabilidades, el empleo de herramientas de escaneo automatizado y la implementación rigurosa de parches constituyen elementos centrales para asegurar una transición protegida hacia ambientes de producción.

Requisitos Previos

- Máquina virtual con Nessus
- Máquina virtual Metasploitable 3
- Ambas máquinas deben estar en la misma red y poder comunicarse (verificar con ping).

Entregables

- Capturas de pantalla de la tarea de configuración y de escaneo completadas en Nessus.

Análisis de Resultados

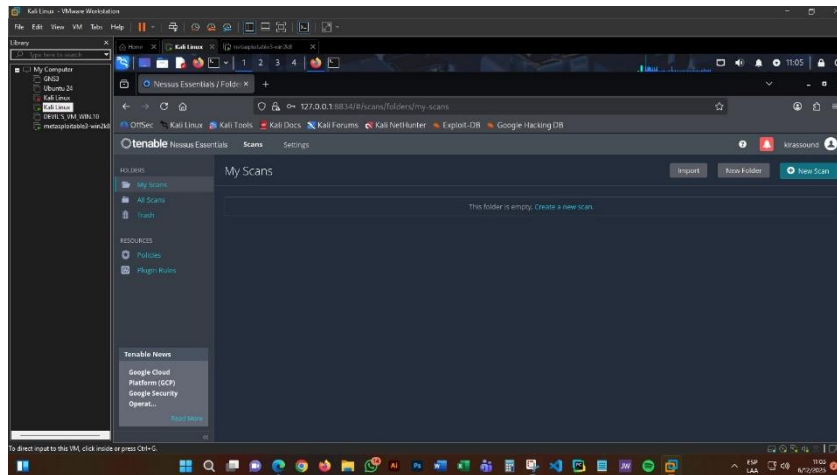
- Una vez completado, revisa el reporte generado.
- Identifica al menos 10 vulnerabilidades de alto riesgo (severidad ≥ 7.0).
- Para cada vulnerabilidad encontrada, registra en una tabla:
 - Nombre de la vulnerabilidad
 - CVSS (puntuación)
 - Puerto/servicio afectado
 - Breve descripción
 - Recomendación de remediación (ejemplo: actualizar servicio, cerrar puerto, etc.)
-
- Tabla con las 5 vulnerabilidades de alto riesgo analizadas.
- Respuesta reflexiva (máximo 1 página):
 - ¿Cuál fue la vulnerabilidad más crítica encontrada y por qué?

- ¿Cómo priorizarías la remediación de las vulnerabilidades identificadas?

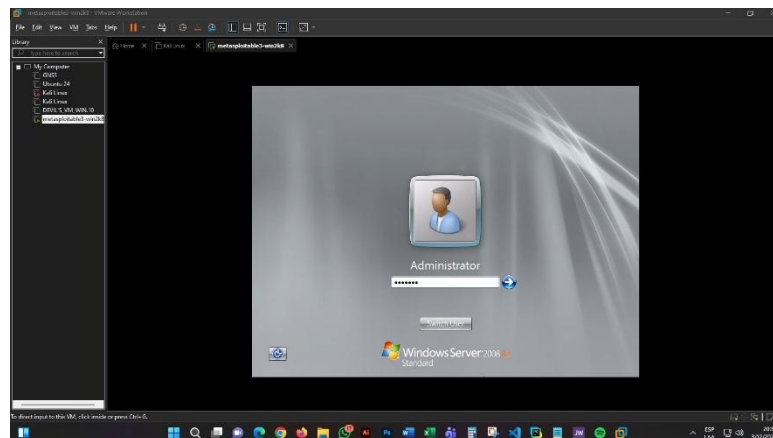
CÁLCULOS / SIMULACIÓN / PROCEDIMIENTO

Requisitos Previos

1. Máquina virtual con Nessus



2. Máquina virtual Metasploitable 3



- Ambas máquinas deben estar en la misma red y poder comunicarse (verificar con ping).

```

kirassound@kali: ~
Session Acciones Editar Vista Ayuda

Active: active (running) since Sat 2025-12-06 10:47:44 -05; 2min 42s ago
Invocation: 338c3556388d45efae97c99fa8dd44a4
Main PID: 1062 (nessus-service)
Tasks: 17 (limit: 3237)
Memory: 1.5G (peak: 1.6G)
CPU: 1min 48.994s
CGroup: /system.slice/nessusd.service
└─1062 /opt/nessus/sbin/nessus-service -q
   1088 nessusd -q

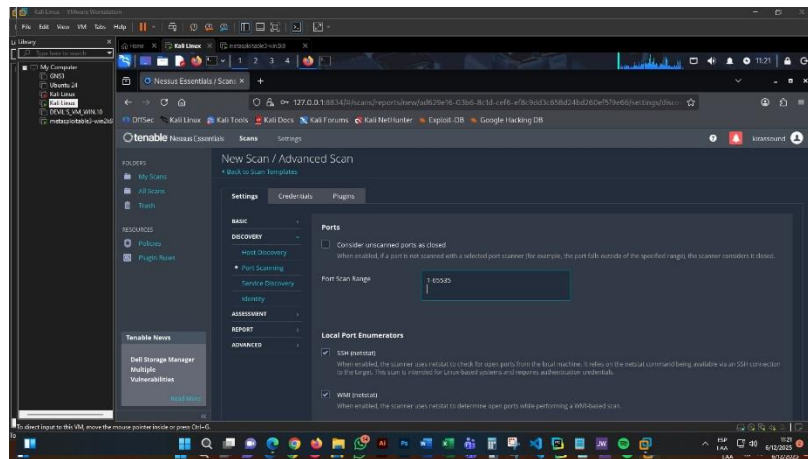
dic 06 10:47:44 kali systemd[1]: Started nessusd.service - The Nessus Vulner
dic 06 10:47:45 kali nessus-service[1062]: nessus-service [1062][INFO] : Nes

(kirassound@kali)-[~]
$ ping 192.168.111.135
PING 192.168.111.135 (192.168.111.135) 56(84) bytes of data:
64 bytes from 192.168.111.135: icmp_seq=1 ttl=128 time=0.496 ms
64 bytes from 192.168.111.135: icmp_seq=2 ttl=128 time=0.389 ms
64 bytes from 192.168.111.135: icmp_seq=3 ttl=128 time=0.237 ms
64 bytes from 192.168.111.135: icmp_seq=4 ttl=128 time=0.284 ms
64 bytes from 192.168.111.135: icmp_seq=5 ttl=128 time=0.251 ms
64 bytes from 192.168.111.135: icmp_seq=6 ttl=128 time=0.295 ms
64 bytes from 192.168.111.135: icmp_seq=7 ttl=128 time=0.256 ms
64 bytes from 192.168.111.135: icmp_seq=8 ttl=128 time=0.371 ms
64 bytes from 192.168.111.135: icmp_seq=9 ttl=128 time=0.281 ms
64 bytes from 192.168.111.135: icmp_seq=10 ttl=128 time=0.295 ms
  
```

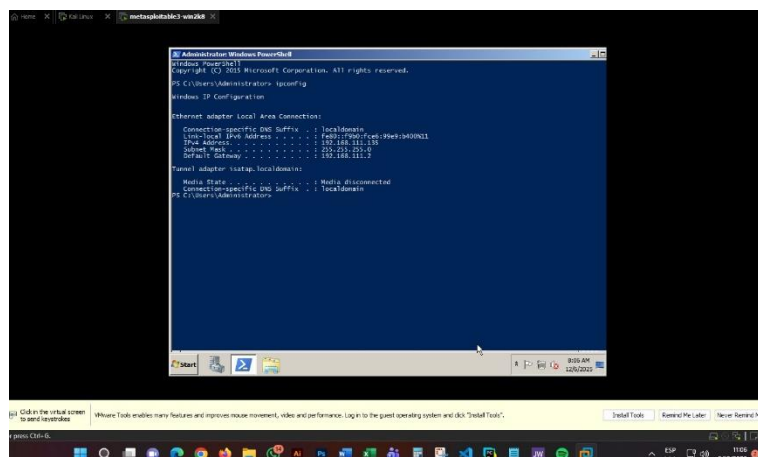
Pasos a Desarrollar

Fase 1: Configuración Inicial

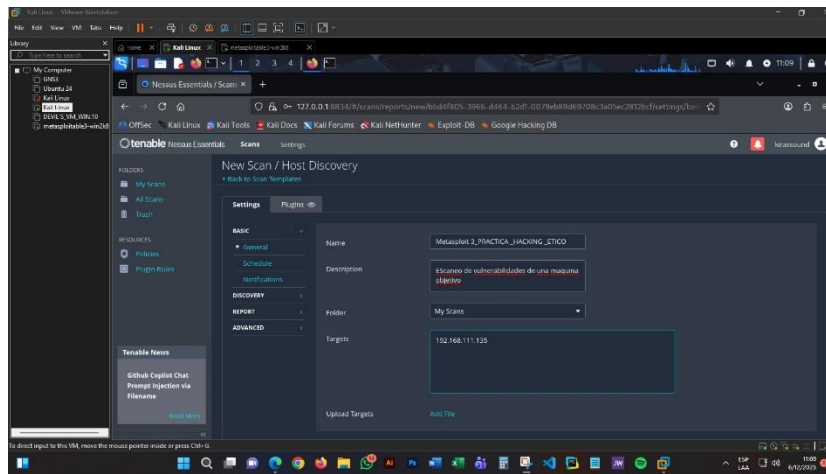
- Inicia nessus y accede a la interfaz web



- Identifica la dirección IP de la máquina Metasploitable 3

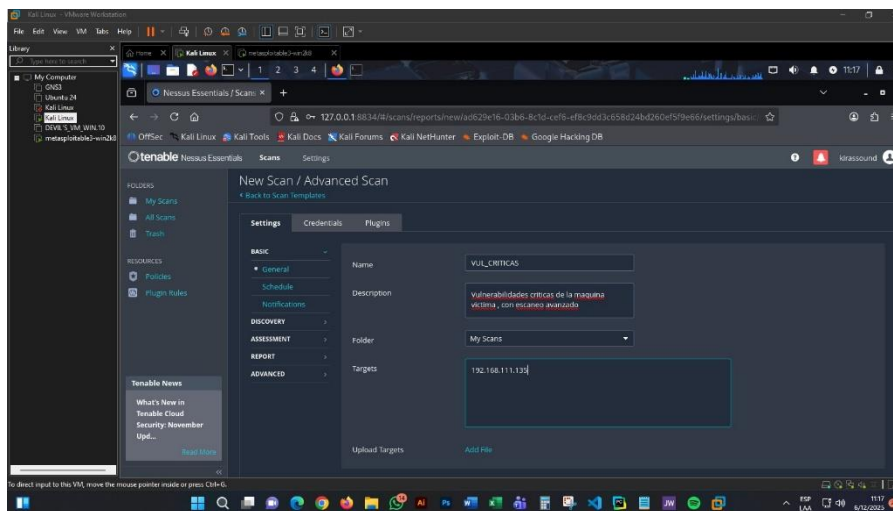


3. En Nessus, crea un nuevo objetivo con la IP de Metasploitable y configura:
 - Rango de IP: solo la IP del objetivo.
 - Puertos: escaneo completo (1-65535).

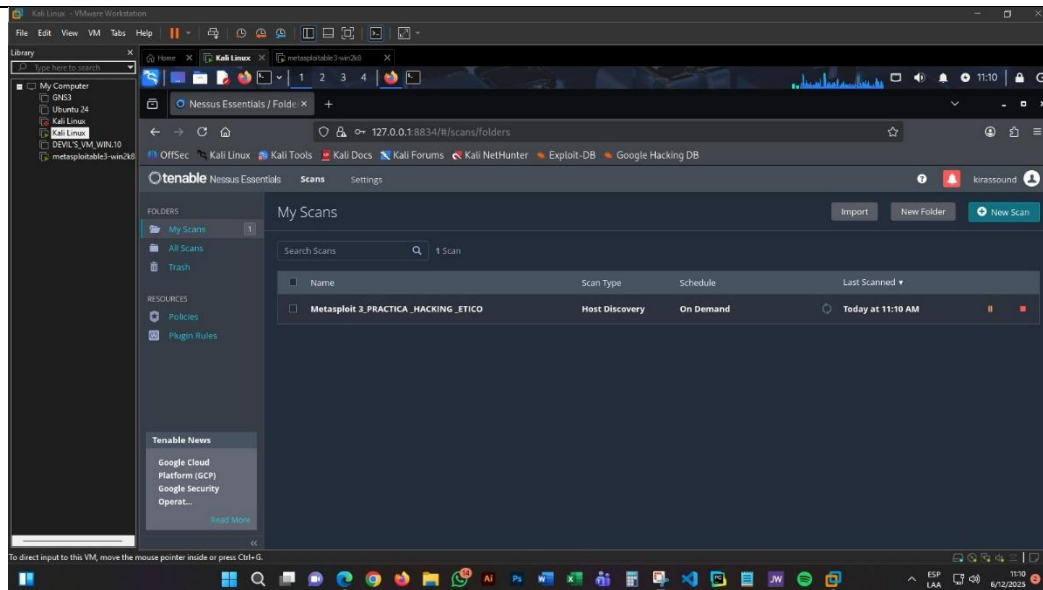


Fase 2: Escaneo de Vulnerabilidades

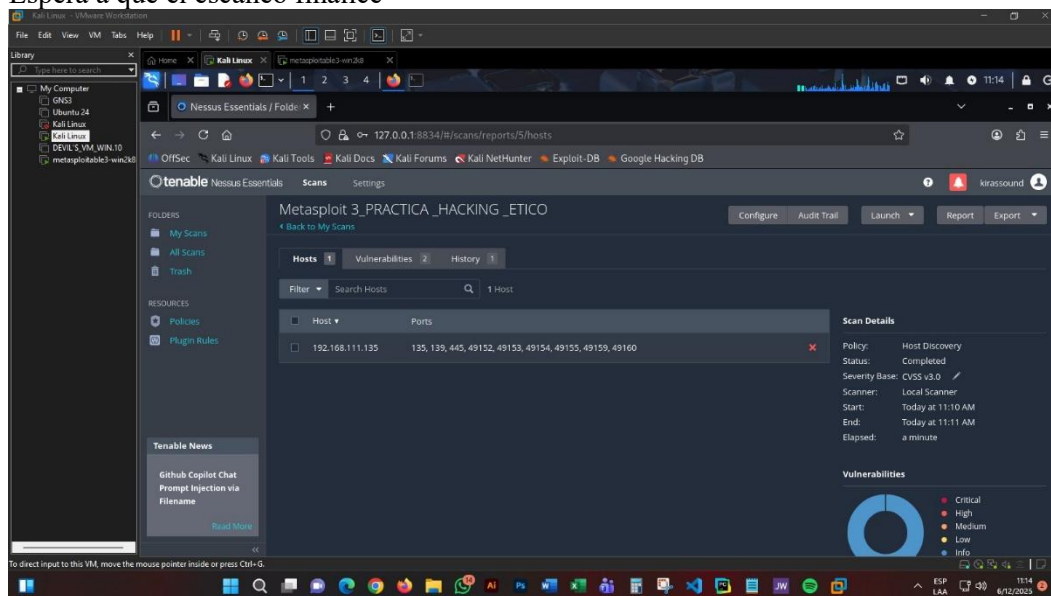
1. Crea una nueva tarea de escaneo:



2. Inicia el escaneo y monitorea su progreso



3. Espera a que el escaneo finalice



Fase 3: Análisis de Resultados

1. Una vez completado, revisa el reporte generado.
2. Identifica al menos 10 vulnerabilidades de alto riesgo (severidad ≥ 7.0).

Kali Linux - VMware Workstation

Library: My Computer, GNS3, Ubuntu 24, Kali Linux, DEVIL_3_VM_WIN_10, metasploitable3-win2k8

Nessus Essentials / Folders: Nessus Essentials

127.0.0.1:8834/#/scans/reports/10/hosts/2/vulnerabilities

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

tenable Nessus Essentials Scans Settings

VUL_CRITICAS / 192.168.111.135

Back to Hosts

Vulnerabilities 30

Filter Search Vulnerabilities 30 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	9.8			Elasticsearch Transport Pr...	Databases	1
MIXED				PHP (Multiple Issues)	CGI abuses	15
MIXED				Zohocorp Manageen...	CGI abuses	15
MIXED				Elasticsearch (Multipl...	CGI abuses	3
MIXED				HTTP (Multiple Issues)	Web Servers	28
MIXED				Apache Tomcat (Mult...	Web Servers	3
MIXED				SMB (Multiple Issues)	Misc.	2

Host Details

IP: 192.168.111.135
Start: Today at 11:28 AM
Auth: N/A

Vulnerabilities

Donut chart showing severity distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Kali Linux - VMware Workstation

Library: My Computer, GNS3, Ubuntu 24, Kali Linux, DEVIL_3_VM_WIN_10, metasploitable3-win2k8

Nessus Essentials / Folders: Nessus Essentials

127.0.0.1:8834/#/scans/reports/10/hosts/2/vulnerabilities

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

tenable Nessus Essentials Scans Settings

Vulnerabilities 30

Filter Search Vulnerabilities 30 Vulnerabilities

MIXED				Apache Tomcat (Mult...	Web Servers	3
MIXED				Openbsd Openssh (...)	Misc.	2
MIXED				SMB (Multiple Issues)	Misc.	2
LOW	2.1 *			ICMP Timestamp Request ...	General	1
MIXED				SSH (Multiple Issues)	Misc.	7
INFO				SMB (Multiple Issues)	Windows	7
INFO				Web Server (Multiple ...)	Web Servers	4
INFO				Oracle Glassfish Serv...	Web Servers	3
INFO				SSH (Multiple Issues)	Service detection	3
INFO				Nessus SYN scanner	Port scanners	43
INFO				Service Plugin ID: 10736	Service detection	18
INFO				DCE Services Enumeration...	Windows	8

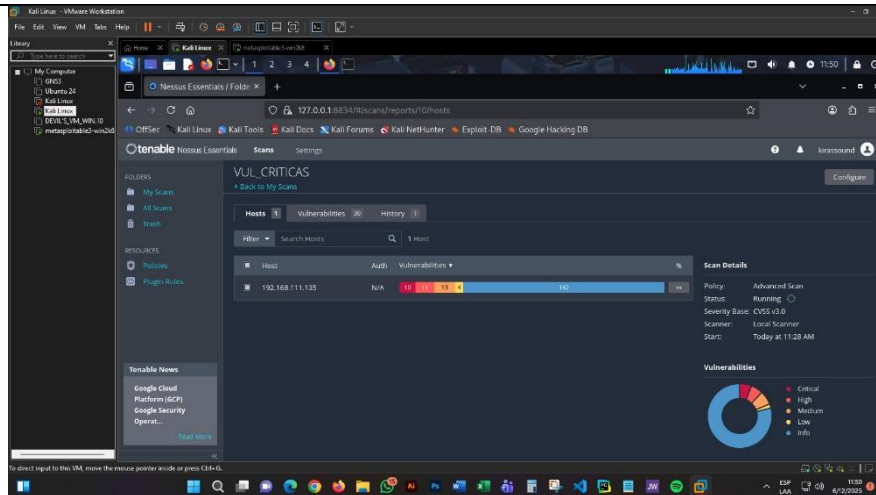
Host Details

IP: 192.168.111.135
Start: Today at 11:28 AM
Auth: N/A

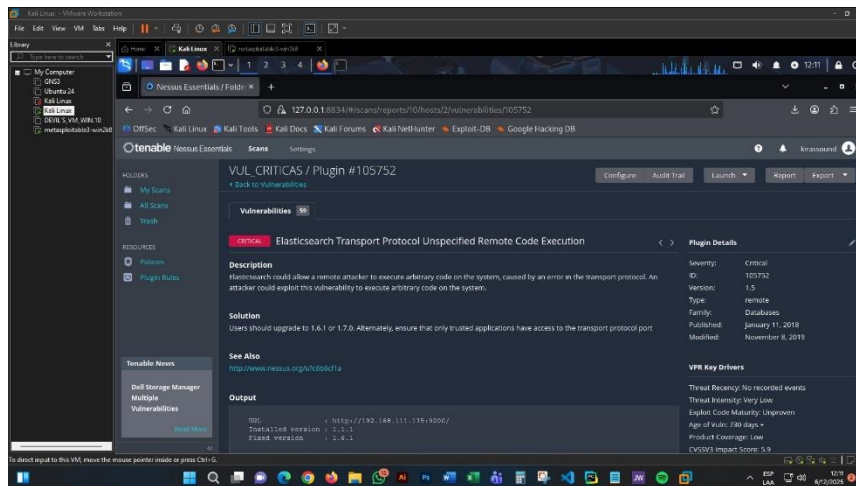
Vulnerabilities

Donut chart showing severity distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

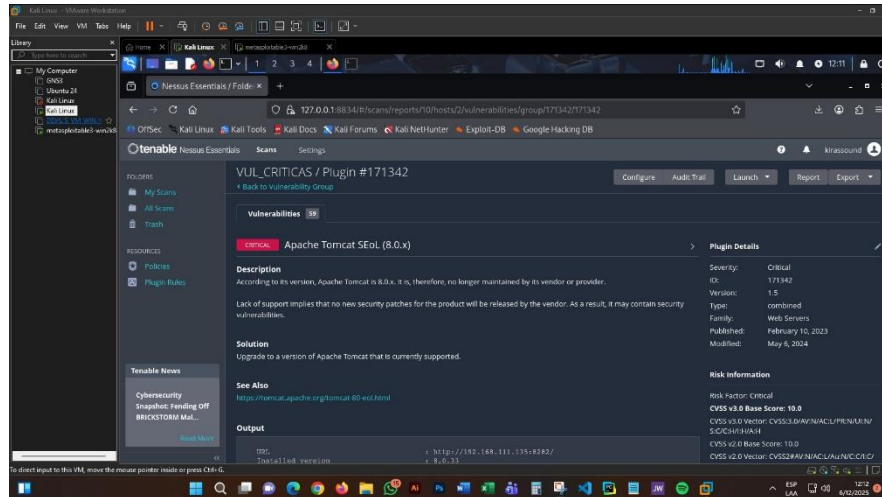


3. Para cada vulnerabilidad encontrada, registra en una tabla:
- Vulnerabilidad N°1



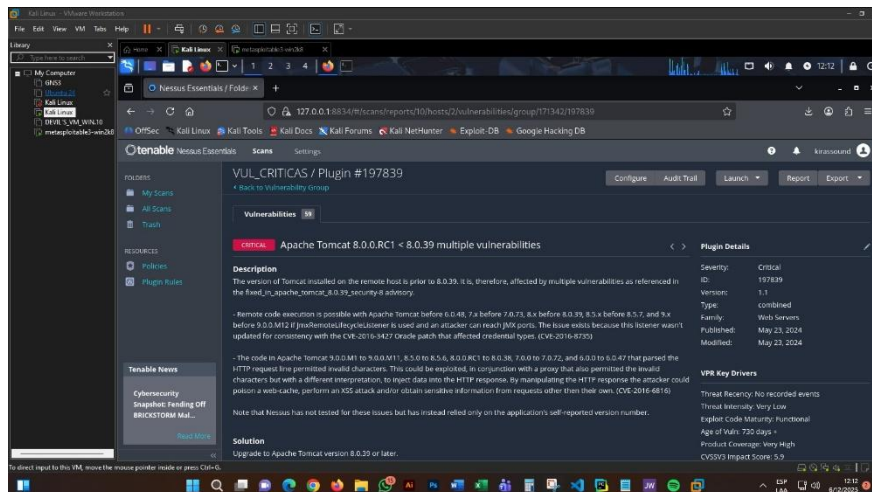
Campo	Detalle
Nombre de la vulnerabilidad	Elasticsearch Transport Protocol – Remote Code Execution
CVSS	9.8 / Crítica
Puerto / servicio afectado	Elasticsearch – 9200
Descripción breve	Un fallo en el protocolo de transporte de Elasticsearch permite que un atacante remoto ejecute código arbitrario en el servidor.
Recomendación de remediación	Actualizar a una versión superior a 1.6.1 o asegurar que el servicio solo pueda ser accedido por aplicaciones confiables.

Vulnerabilidad N°2



Campo	Detalle
Nombre de la vulnerabilidad	Apache Tomcat SEoL (8.0.x)
CVSS	10.0 (Crítica)
Puerto / servicio afectado	HTTP – 8282
Descripción breve	La versión de Apache Tomcat instalada es 8.0.x, la cual se encuentra fuera de soporte, por lo que no recibe actualizaciones ni parches de seguridad. Esto puede permitir explotación mediante vulnerabilidades no corregidas.
Recomendación de remediación	Actualizar Apache Tomcat a una versión soportada (preferiblemente 9.x o 10.x).

Vulnerabilidad N°3





Campo	Detalle
Nombre de la vulnerabilidad	Apache Tomcat 8.0.0.RC1 < 8.0.39 Multiple Vulnerabilities
CVSS	10.0 (Crítica)
Puerto / servicio afectado	HTTP – 8282
Descripción breve	Versiones antiguas de Apache Tomcat son vulnerables a ejecución remota, inyección HTTP, obtención de información sensible, entre otras fallas explotables mediante JMX y HTTP.
Recomendación de remediación	Actualizar a versión 8.0.39 o superior (recomendado Tomcat 9 o 10).

Vulnerabilidad N°4

4. Filtra los resultados por:

Vulnerabilidad

Servicio

¿Es servicio web?

Motivo

Apache Tomcat Default Files

Apache Tomcat

Sí

Archivos expuestos por servidor HTTP.

Apache Tomcat SEoL (8.0.x)

Apache Tomcat

Sí

Servidor web Java accesible vía HTTP.

Apache Tomcat 8.0.0RC1 < 8.0.39 – Multiple Vulnerabilities

Apache Tomcat

Sí

Vulnerabilidades a través de peticiones HTTP.

Elasticsearch ESA-2015-06 (RCE)

Elasticsearch

Sí

Proporciona API web HTTP/JSON.

SSL/TLS Logjam

Servicio HTTPS

Sí

Afecta cifrado en servicios SSL/TLS.

Se concluye que todas estas vulnerabilidades afectan servicios web directamente, ya sea en HTTP, HTTPS o API REST.

Vulnerabilidades de autenticación débil.

Vulnerabilidad	¿Autenticación débil?	Motivo
Apache Tomcat Default Files	Sí	Archivos y páginas accesibles sin autenticación.
Apache Tomcat 8.0.0RC1 < 8.0.39 Multiple Vulnerabilities	Sí	Varias fallas explotables sin autenticación.
Elasticsearch RCE (ESA-2015-06)	Sí	La ejecución remota no requiere autenticación.
SSL/TLS Logjam	No	No involucra credenciales, sino cifrado débil.
Windows 2008 sin soporte	No	Es desactualización, no autenticación.
Tomcat SEoL (fin de soporte)	Parcial	La versión antigua puede tener fallos, pero no se indica directamente.



- Se concluye Las vulnerabilidades que implican autenticación débil son:
 - ✓ Apache Tomcat Default Files
 - ✓ Apache Tomcat Multiple Vulnerabilities
 - ✓ Elasticsearch RCE

Respuesta reflexiva (máximo 1 página):

- ¿Cuál fue la vulnerabilidad más crítica encontrada y por qué?

La vulnerabilidad más crítica es Apache Tomcat 8.0.0RC1 < 8.0.39 – Multiple Vulnerabilities (Critical).

Esto se debe a que combina:

- Ejecución remota de código (RCE)
- Explotación sin autenticación previa
- Múltiples vectores (HTTP, JMX, configuración insegura)
- Producto fuera de soporte, sin parches de seguridad
- Impacto directo en la disponibilidad, integridad y confidencialidad

La posibilidad de tomar control del servidor a través de un servicio web expuesto convierte esta vulnerabilidad en la más peligrosa, ya que puede resultar en un compromiso total del sistema.

- ¿Cómo priorizarías la remediación de las vulnerabilidades identificadas?

El orden recomendado de remediación, basado en riesgo y facilidad de explotación, es:

2. Actualizar Apache Tomcat a una versión soportada.

Soluciona múltiples CVEs y elimina vectores de RCE.

3. Actualizar Elasticsearch a versión segura.

El RCE sin autenticación la vuelve muy prioritaria.

4. Eliminar archivos por defecto en Apache Tomcat.

Evita divulgación de información y vectores de reconocimiento.

5. Corregir la vulnerabilidad Logjam (mejorar parámetros TLS).

Evita degradación de cifrado en servicios HTTPS.

6. Plan de migración para Windows Server 2008.

El sistema está sin soporte y no recibe parches.

7. Aplicar controles de acceso (ACL, firewall, segmentación).

Limitar exposición de Tomcat y Elasticsearch a solo redes internas.

8. Implementar autenticación donde no existe.

Especialmente en APIs de administración y paneles web.

- ¿Qué limitaciones tiene un escaneo no autenticado como el realizado?

Un escaneo no autenticado solo evalúa lo visible desde el exterior, lo que genera varias limitaciones:

- **No revisa configuraciones internas**, permisos ni usuarios.
- **No detecta contraseñas débiles**, políticas de bloqueo o auditoría.
- **No analiza software interno**, solo lo que está expuesto a la red.
- **Puede generar falsos positivos**, al inferir versiones por banners.
- **No identifica mitigaciones aplicadas**, hardening interno o parches parciales.
- **No evalúa seguridad del sistema operativo**, solo servicios visibles.
- **No detecta malware, persistencia o movimientos laterales internos**.

En resumen, un escaneo no autenticado sirve para identificar la **superficie de ataque externa**, pero no refleja el **estado real completo de seguridad del sistema**, por lo que debe complementarse con un escaneo autenticado para una evaluación integral.

CUESTIONARIO

CUESTIONARIO

Preguntas

1. Limitaciones del escaneo:

El escaneo realizado fue "no autenticado". ¿Qué tipos de vulnerabilidades podrías estar omitiendo con este enfoque? Da dos ejemplos específicos de vulnerabilidades que solo se detectarían con escaneo autenticado.

2. Tasa de falsos positivos:

Durante tu análisis, ¿identificaste algún resultado que pudiera ser un falso positivo? Describe cómo verificarías manualmente una vulnerabilidad reportada para confirmar su existencia real.

3. Priorización de remediación:

Si tuvieras que crear un plan de remediación para las vulnerabilidades encontradas, ¿qué criterios usarías para priorizar (aparte del CVSS)? Menciona al menos tres criterios adicionales.

4. Contexto de seguridad:

Imagina que Metasploitable 3 es un servidor de desarrollo en una empresa. ¿Cómo diferiría tu reporte y recomendaciones si este fuera un servidor de producción con datos sensibles?

5. Mejora del proceso:

Basándote en esta práctica, ¿qué mejorarías en el proceso de escaneo si tuvieras que repetirlo? Considera aspectos como: alcance, configuración, tiempo, o análisis posterior.

RESULTADOS:

El análisis efectuado logró reconocer un grupo considerable de deficiencias que impactan de manera directa a los servicios web y a los elementos internos del servidor examinado. Entre los resultados más notables resaltan fallas graves localizadas en entornos como Apache Tomcat y Elasticsearch, que se hallan accesibles a través de interfaces HTTP visibles desde el exterior. Estas deficiencias posibilitan desde la revelación de datos

confidenciales hasta la posibilidad de ejecutar código a distancia sin necesidad de autenticación, lo cual constituye una amenaza seria para la integridad, la disponibilidad y la confidencialidad de los sistemas. La evaluación también pone de manifiesto hábitos de configuración inapropiados y una carencia de mantenimiento general en servicios fundamentales.

De igual forma, se identificó la visibilidad pública de archivos por defecto en Tomcat, lo que brinda a un intruso la oportunidad de conseguir información de reconocimiento, versiones específicas del servicio y entrada a recursos que no tendrían que estar accesibles de forma pública. Esta clase de fallos normalmente se utiliza durante las etapas iniciales de un ataque, puesto que permite reunir pormenores técnicos que aumentan las opciones de una explotación efectiva. La existencia de estos archivos verifica que el servidor no ha sido reforzado de forma correcta, dejando al descubierto ajustes internos y componentes que se debieron eliminar o restringir desde la puesta en producción.

Un aspecto grave adicional detectado en el transcurso del escaneo es la utilización de versiones antiguas y sin mantenimiento oficial, como Windows Server 2008 y Apache Tomcat 8.0.x. Estos elementos ya no reciben parches de seguridad, lo que eleva el riesgo de ser atacados mediante vulnerabilidades conocidas. Un actor malintencionado con entrada a estos servicios puede emplear métodos de ataque de dominio público y bien conocidos para afectar el sistema con relativa sencillez. La ausencia de mantenimiento y actualización sigue siendo uno de los factores más decisivos en la exposición del servidor, sobre todo en ambientes que gestionan servicios web y aplicaciones de acceso público.

Para finalizar, el estudio mostró flaquezas en la configuración relacionada con cifrado, en concreto la vulnerabilidad Logjam en los protocolos SSL/TLS. Esto admite el uso de claves frágiles y favorece ataques que reducen la fuerza del cifrado, poniendo en peligro la seguridad de las comunicaciones protegidas. La existencia de múltiples vulnerabilidades críticas y de alto nivel demuestra que el servidor exhibe una superficie de ataque notablemente extensa. Al sumarse configuraciones inseguras, servicios sin asistencia técnica y fallos web que pueden ser aprovechados de manera remota, el entorno se encuentra en una situación de riesgo operativo elevado. En resumen, estos hallazgos destacan la necesidad inmediata de implementar acciones correctivas y de robustecer la postura de seguridad del sistema.

CONCLUSIONES:

1. Amplia Área de Ataque y Peligro Operacional el análisis de vulnerabilidades realizado con Nessus ha evidenciado que el servidor Metasploitable presenta un área de ataque significativamente amplia a través de sus conexiones de red la existencia de diversos servicios accesibles y visibles desde el exterior, muchos de los cuales tienen defectos serios, indica que el entorno está en una situación de alto riesgo operativo. La combinación de servicios desactualizados, cifrado débil y la exposición de interfaces administrativas aumenta considerablemente este peligro.

2. Gran Cantidad de Vulnerabilidades Críticas y Severas el informe reveló la identificación de un número considerable de fallas críticas y severas (con severidad de 7. 0 o más en CVSS), encontrándose hasta 11 vulnerabilidades catalogadas como Críticas/Altas. Esto resalta la falta de una gestión continua para actualizar y fortalecer las configuraciones, haciendo necesario llevar a cabo acciones correctivas de forma inmediata.

3. Vulnerabilidad Severamente Crítica en Apache Tomcat (Ejecución Remota de Código sin Autenticación) La vulnerabilidad más alarmante detectada está relacionada con Apache Tomcat (versiones desde 8. 0. 0RC1 hasta 8. 0. 39), con un puntaje de 10. 0 en CVSS. Esta falla es particularmente peligrosa ya que combina la Ejecución Remota de Código y la posibilidad de explotación sin la necesidad de autenticación previa, lo que permite a un atacante tomar control total del servidor a través de un servicio web vulnerable, comprometiendo así el sistema en su totalidad.

4. Peligro de Servicios Desactualizados y Fuera de Soporte se identificó el uso de versiones anticuadas y sin soporte oficial, como Windows Server 2008 y Apache Tomcat 8. 0. x. La inexistencia de soporte significa que estos softwares ya no reciben actualizaciones de seguridad, lo que facilita que un actor malicioso pueda usar técnicas de ataque bien conocidas para comprometer el sistema con facilidad.

5. Vulnerabilidad Crítica en Elasticsearch con Ejecución Remota de Código se halló una falla severamente crítica en el Protocolo de Transporte de Elasticsearch que permite la ejecución remota de código en el servidor. Esta falta de seguridad, clasificada con un puntaje de 9.8 en CVSS, no requiere autenticación y puede ser aprovechada por un atacante a distancia. Esto muestra una grave exposición en las interfaces de aplicación, aumentando significativamente el riesgo de que el sistema sea vulnerado.

6. Exposición de Información por Archivos Predeterminados en Tomcat se detectó la presencia de archivos predeterminados accesibles públicamente en Apache Tomcat, lo que refleja configuraciones inadecuadas y una falta de fortalecimiento del servidor. Estos archivos permiten a un atacante reunir información sobre la configuración, obtener versiones específicas del servicio y acceder a recursos que deberían estar protegidos, facilitando las primeras fases de un ataque.

7. Configuración Inadecuada del Cifrado (Vulnerabilidad Logjam) El análisis reveló debilidades en la configuración del cifrado SSL/TLS, en particular la vulnerabilidad Logjam (CVE-2015-4000). Esta falla impacta el proceso de intercambio de claves Diffie-Hellman, permitiendo a un atacante reducir la calidad de la conexión TLS y potencialmente violar el cifrado, poniendo en riesgo la privacidad de la información transmitida.

8. Limitaciones del Análisis No Autenticado el método de escaneo no autenticado, realizado desde el exterior sin credenciales, tiene limitaciones importantes. Solo evalúa lo que es visible desde fuera, sin revisar configuraciones internas, permisos de usuarios o políticas de seguridad. Por ello, el escaneo no refleja de manera precisa el estado total de seguridad del sistema y debe complementarse con un escaneo autenticado para obtener una evaluación completa.

9. Priorización de Remediación Según Impacto y Explotación la remediación debe ser priorizada basándose en el impacto posible y la facilidad de explotación las vulnerabilidades de Ejecución Remota de Código y las que no requieren autenticación, como las de Tomcat y Elasticsearch, deberían ser la prioridad máxima el enfoque sugerido es: Actualizar Apache Tomcat, Actualizar Elasticsearch, y finalmente eliminar archivos predeterminados.

10. Cumplimiento de Objetivos de la Práctica A pesar de los hallazgos de riesgo, la práctica alcanzó su meta general: Los estudiantes lograron configurar y llevar a cabo un análisis de vulnerabilidades con Nessus, examinar los resultados, identificar vulnerabilidades críticas y crear una base para un reporte fundamental. Esto demuestra el aprendizaje práctico sobre la función de las herramientas de escaneo automatizado en la detección temprana de vulnerabilidades.

RECOMENDACIONES:

Priorizar la Renovación y Migración de Servicios Esenciales

La acción más prioritaria es intervenir en aquellos servicios que tienen vulnerabilidades de Ejecución Remota de Código (RCE) y en los que han llegado al final de su soporte (EoL).

Actualización Inmediata de Apache Tomcat y Elasticsearch: Se debe llevar a cabo la actualización de Apache Tomcat a una versión respaldada y estable (preferiblemente 9.x o 10.x). Esto resolverá diversas fallas críticas, incluida la RCE sin necesidad de autenticación (CVSS 10.0). De manera análoga, Elasticsearch necesita ser actualizado a una versión superior a 1.6.1 para solucionar la vulnerabilidad de RCE asociada al protocolo de transporte (CVSS 9.8).

Paso Clave: Realizar un proceso de parcheo gradual y confirmar la compatibilidad de las aplicaciones antes de proceder con la migración en el entorno de producción.

Plan de Migración para Windows Server 2008: Dado que Windows Server 2008 ya no tiene soporte (EoL), no recibe actualizaciones de seguridad. Es necesario comenzar un plan de migración para trasladar el servidor y

sus servicios a un sistema operativo más reciente (como Windows Server 2019 o superior) para garantizar la continua recepción de parches y medidas de seguridad.

Implementar Aumento de Seguridad y Controles de Acceso

Es esencial minimizar la superficie de ataque del servidor mediante configuraciones más seguras y limitando la exposición innecesaria de servicios. Eliminación de Archivos y Configuraciones Predeterminados: Es fundamental eliminar todos los archivos y páginas predeterminados de la instalación de Apache Tomcat (incluyendo manuales, ejemplos y páginas de prueba). Esto previene la divulgación de información sensible (como versiones específicas del servicio) y anula vectores que un atacante podría explotar.

Segmentación de la Red y Aplicación de ACL/Firewall: Establecer Controles de Acceso (ACL) o reglas de firewall que restrinjan el acceso a servicios críticos (como Tomcat y Elasticsearch) únicamente a las redes internas o a los hosts que realmente los necesitan.

Ejemplo: Limitar el acceso a los puertos de administración (como el puerto 9200 de Elasticsearch) exclusivamente a las direcciones IP de los administradores y no a toda la red interna.

Mejorar el Cifrado TLS: Abordar la vulnerabilidad Logjam. Esto implica incrementar la longitud de los parámetros de Diffie-Hellman para prevenir la degradación del cifrado y asegurar la aceptación solo de suites de cifrado modernas y seguras, ayudando así a proteger la confidencialidad de la información que se transmite por conductos cifrados.

Establecer un Proceso de Evaluación de Seguridad Exhaustivo

Para asegurar una robustez en la postura de seguridad, es vital perfeccionar el proceso de escaneo y validación de vulnerabilidades.

Transición a Escaneos Autenticados: El proceso de escaneo debe llevarse a cabo nuevamente utilizando credenciales de acceso (escaneo autenticado). Un escaneo autenticado puede identificar vulnerabilidades internas que no se pueden detectar en un escaneo sin autenticación, tales como configuraciones inseguras, software instalado, permisos incorrectos o contraseñas débiles. Esto proporcionará una representación más precisa del estado real de seguridad del sistema.

Revisión Manual (Comprobación de Falsos Positivos): Tras cada análisis, el experto necesita llevar a cabo una revisión manual de las vulnerabilidades de alto riesgo detectadas, especialmente aquellas relacionadas con las versiones de los banners. Esto se puede realizar a través de la explotación controlada o utilizando herramientas de línea de comandos, como Nmap, curl o Metasploit, para verificar que la vulnerabilidad realmente está presente y puede ser aprovechada, disminuyendo así la cantidad de falsos positivos.

Mantenimiento Continuo de Parches: Es necesario implementar un procedimiento riguroso y periódico para la gestión de parches y actualizaciones en todos los sistemas operativos y aplicaciones, garantizando que tanto el servidor de desarrollo como el que se utilizará en producción, no regresen a un estado donde estén utilizando software obsoleto.

REFERENCIAS:

Tenable. (s.f.). Plugin 119499 – Elasticsearch Remote Code Execution. Recuperado de <https://www.tenable.com/plugins/nessus/119499>

Acunetix. (s.f.). TLS/SSL Logjam Attack Vulnerability (CVE-2015-4000). Recuperado de <https://www.acunetix.com/vulnerabilities/web/tls-ssl-logjam-attack/>

IBM. (s.f.). Diffie-Hellman vulnerability known as Logjam may affect IBM WebSphere. Recuperado de <https://www.ibm.com/support/pages/diffie-hellman-vulnerability-known-logjam-apache-tomcat-may-affect-ibm-websphere-application-server-community-edition-cve-2015-4000>

Aviram, N., Schinzel, S., Somorovsky, J., Heninger, N., Dankel, M., Valenta, L., Cohnsey, S., Engels, S., Bolte, M., Steube, J., & Paar, C. (2016). DROWN: Breaking TLS using SSLv2. arXiv. <https://arxiv.org/abs/1602.02396>



Metasploitable3: Vulnerabilidades documentadas

Rapid7. Vulnerabilities — Metasploitable3 Wiki. Recuperado de GitHub.
GitHub

APA: Rapid7. (2019, marzo 12). Vulnerabilities — Metasploitable3 Wiki. GitHub.
<https://github.com/rapid7/metasploitable3/wiki/Vulnerabilities>

EternalBlue / SMBv1 / MS17-010 — descripción del exploit y su impacto

Avast. (2020, junio 18). ¿Qué es EternalBlue y por qué el exploit MS17-010 sigue siendo relevante? Avast.
Avast

APA: Avast. (2020, junio 18). ¿Qué es EternalBlue y por qué el exploit MS17-010 sigue siendo relevante?
Avast. <https://www.avast.com/es-es/c-eternalblue>

Detalles técnicos de la vulnerabilidad CVE-2017-0144 (SMB Remote Code Execution)

INCIBE-CERT. (2017, marzo 17). CVE-2017-0144 — Vulnerabilidad en SMBv1 en múltiples productos de Microsoft Windows. INCIBE.
INCIBE

NVD (National Vulnerability Database). CVE-2017-0144 Detail. NVD / NIST.
NVD

APA: INCIBE-CERT. (2017, marzo 17). CVE-2017-0144 — vulnerabilidad en SMBv1 en múltiples productos de Microsoft Windows. INCIBE. <https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades/cve-2017-0144>

APA: NVD. (2017). CVE-2017-0144 Detail. National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/cve-2017-0144>

Investigación académica sobre explotación de MS17-010 / creación de nodo vulnerable

Novokhrestov, A., Kalyakin, A., Kovalenko, A., & Repkin, V. (2024). Creating a vulnerable node based on the vulnerability MS17-010. arXiv.
arXiv

APA: Novokhrestov, A., Kalyakin, A., Kovalenko, A., & Repkin, V. (2024). Creating a vulnerable node based on the vulnerability MS17-010. arXiv. <https://arxiv.org/abs/2401.14979>